

Script de soutenance - PixelStore

Infrastructure cloud AWS sécurisée & automatisée - 10 minutes, 3 intervenants

Équipe (impact égal) : Jimmy Barbier - Dorian Poncelet - Matthieu Broquard Répartition : ~3 min 20 chacun. Bascule d'orateur indiquée à chaque transition.

PARTIE 1 - JIMMY BARBIER (~3 min 20) - Infrastructure & architecture

Slides 1, 2, 4, 5, 6, 7

Slide 1 - Titre (15 s) " Bonjour à tous. Nous sommes Jimmy, Dorian et Matthieu, et nous vous présentons PixelStore : une infrastructure cloud AWS sécurisée et entièrement automatisée, réalisée en équipe dans le cadre du projet final. Je commence par l'architecture, Matthieu enchaînera sur l'application et le test d'intrusion, et Dorian conclura sur l'analyse des risques. "

Slide 2 - Contexte & objectifs (35 s) " PixelStore est une PME parisienne de 35 employés, e-commerce de smartphones haut de gamme. Quatre objectifs : la disponibilité - rester en ligne même si une zone AWS tombe ; la sécurité, avec une défense en profondeur ; l'évolutivité pour absorber les pics ; et l'automatisation. En chiffres : 77 ressources AWS, 17 modules Terraform, 2 zones de disponibilité, et une seule commande de déploiement. "

Slide 4 - Architecture globale (35 s) " Tout repose sur un VPC Multi-AZ en région Paris, eu-west-3, pour la conformité RGPD. Deux zones, des subnets publics pour l'ALB et les serveurs, des subnets privés pour la base de données. Le trafic entre par Cloudflare puis le WAF, traverse le load balancer, atteint les instances Flask, et seules ces instances parlent à la base. "

Slide 5 - Défense en profondeur (45 s) " La sécurité ne repose jamais sur un seul contrôle : sept couches indépendantes. Le périmètre avec Cloudflare pour le TLS et le WAF AWS. Le réseau avec des Security Groups en cascade et des NACLs. L'identité avec un rôle IAM en moindre privilège, sans clé SSH, accès par SSM. Les secrets dans Secrets Manager, jamais en clair. La détection avec GuardDuty. Et les données : RDS Multi-AZ, chiffrées au repos en AES256. "

Slide 6 - Le WAF en pratique (35 s) " Le WAF a trois règles : protection OWASP, anti-injection SQL, et limitation de débit anti-DDoS. Au test, tous les payloads et quatre variantes d'évasion ont été bloqués en 403. Mais le message clé : la vraie protection est dans le code. Nos requêtes paramétrées neutralisent déjà les injections. Le WAF ne protège que ce qu'il inspecte - il ne remplace pas un code sécurisé. "

Slide 7 - Infrastructure as Code (35 s) " Toute l'infra est en Terraform : déclaratif, idempotent, versionné sur GitHub, reproductible grâce à un backend distant S3 avec verrou DynamoDB. Un seul `terraform apply` crée les 77 ressources et rend le site opérationnel en 10 à 15 minutes. Je passe la parole à Matthieu. "

PARTIE 2 - MATTHIEU BROQUARD (~3 min 20) - Application, coûts & test d'intrusion

Slides 3, 8, 9, 10, 11, 12

Slide 3 - Le site PixelStore (25 s) " Merci Jimmy. Voici l'application : un site Flask complet - catalogue de 9 modèles, fiches produits, panier, et authentification. Sessions Flask signées, mots de passe hachés avec bcrypt. "

Slide 8 - Application & haute disponibilité (40 s) " Côté résilience : l'application est servie par Unicorn, un serveur de production. L'Auto Scaling lance une 2e instance au-delà de 60 % de CPU. La base RDS est en Multi-AZ : une réplique synchrone bascule automatiquement en 1 à 2 minutes. Pour la reprise : un RPO d'environ 15 minutes (snapshot toutes les 12 h + binlogs/PITR), un RTO d'environ 15 minutes - Terraform recrée tout depuis le code. "

Slide 9 - Coûts & FinOps (35 s) " Le coût : 150 € par mois, soit 1 800 € par an en On-Demand, et moins de 900 € avec un Savings Plan. Face à une infra on-premise équivalente, c'est plus de 18 000 € d'économie la première année - sans investissement initial, haute disponibilité incluse, et données en France. "

Slide 10 - Test d'intrusion (35 s) " Nous avons mené un test d'intrusion en boîte grise. Méthodologie classique : reconnaissance, identification du WAF, tests d'injection SQL, analyse de l'authentification et de la configuration. Ce qui a résisté : les injections SQL, neutralisées par les requêtes paramétrées ; le WAF ; et le cookie HttpOnly contre le vol par XSS. "

Slide 11 - 8 constats, tous corrigés (45 s) " Le test a remonté 8 constats - aujourd'hui tous corrigés dans le code. F1, le TLS, via Cloudflare. F2, passage à Unicorn. F3, les en-têtes de sécurité. F4, les cookies durcis. F5, plus d'énumération de comptes. F6 et F8, une SECRET_KEY forte dans Secrets Manager. F7, une vraie politique de mot de passe. Et nous avons même trouvé et corrigé une faille hors pentest : un Open Redirect. "

Slide 12 - Axes d'amélioration (25 s) " Pour aller plus loin : chiffrer aussi le tronçon Cloudflare-ALB, formaliser la gouvernance, activer le MFA, un annuaire centralisé, un pipeline CI/CD et un RPO réduit. Je laisse Dorian pour l'analyse des risques. "

PARTIE 3 - DORIAN PONCELET (~3 min 20) - Gouvernance, risques & conformité

Slides 13, 14, 15, 16

Slide 13 - Analyse GRC (50 s) " Merci Matthieu. Nous avons croisé trois référentiels. ISO 27001 : 93 contrôles évalués, score de maturité 1,72 sur 5 - la base technique est solide, mais la gouvernance organisationnelle est en retard. NIST CSF 2.0 : Tier 1, avec les fonctions Réponse et Reprise quasi inexistantes. Et FAIR, pour chiffrer le risque en euros. Le constat : les écarts ne sont pas techniques, ils sont organisationnels. "

Slide 14 - Exposition financière FAIR (55 s) " FAIR quantifie le risque en euros via une simulation Monte Carlo, 10 000 itérations. Avant durcissement : environ 192 000 € d'exposition annuelle, dont 145 000 pour le seul HTTP en clair, et 30 000 pour la SECRET_KEY faible. Après nos corrections de F1

et F8, ces deux scénarios tombent à zéro : il ne reste que le risque de fuite de données RGPD, à 17 000 € par an. C'est 175 000 € d'exposition supprimée - et on passe sous le seuil cible de 30 000. "

Slide 15 - Plan de traitement (40 s) " Le plan est priorisé par impact financier. Le volet immédiat est déjà fait : TLS, SECRET_KEY, en-têtes, cookies, politique de mot de passe. Restent à court terme la gouvernance : procédure de réponse à incident, registre RGPD Article 30, engagements de confidentialité, test de restauration. Et à moyen terme : séparation des environnements, inventaire des actifs, plan de continuité. "

Slide 16 - En résumé (30 s) " Pour conclure : une infrastructure de niveau production, 77 ressources en une commande ; sécurisée par conception, auditée puis durcie ; un risque maîtrisé et chiffré ; conforme RGPD et entièrement reproductible. Merci de votre attention - nous sommes à votre disposition pour vos questions. "

Repères de minutage

Intervenant	Slides	Durée cible
Jimmy Barbier	1, 2, 4, 5, 6, 7	~3 min 20
Matthieu Broquard	3, 8, 9, 10, 11, 12	~3 min 20
Dorian Poncelet	13, 14, 15, 16	~3 min 20
Total	16 slides	~10 min